Módulo 4 – Aula ao Vivo

Backup e Segurança da Informação (PSI)

Prof. Robson Siscoutto

Unoeste | EAD

Material de Estudo

UA	Nome da Unidade de Aprendizagem
1	Backup e Restauração
2	Política de Segurança de Informação (PSI)

1º Módulo
Infraestrutura de TI e Sistemas de Informação
- datacenter e nuvem (tiers)
- Infra tipo Iaas, PaaS, SaaS

2º Módulo
Infraestrutura de TI (Dados e Redes) e Virtualização (SO)
- Sistemas de Arquivos, Banco de Dados – DaaS,
- Infra de Redes em Datacenters, Virtualização

3º Módulo
Armazenamento de Informações e Proteção RAID
- Estrutura de Armazenamento: DAS, NAS, SAN, FAS e IP-SAN
- RAID 0, 1, 2, 3, 4, 5, 6, 01 e 10

Atividade 4 - Backup e Segurança da Informação
Questionário → 24/03 → INDIVIDUAL

Entrega do Resumo Aula ao Vivo - 17/03

UA	Nome da Unidade de Aprendizagem
1	Backup e Restauração

- O **backup** nada mais é do que a **cópia de segurança das informações armazenadas**, ou seja, é a copia usada na restauração **dos dados** em casos de problemas, bugs ou danificação da informação original.

- Os dados das empresas são de vital importância para elas. Os **backups fornecem proteção contra perda de dados**, bem como facilitam os testes em estruturas maiores.

Contextualização

- *Backup* é a **cópia dos dados em produção** criada e mantida com o **único propósito** de recuperar dados apagados e corrompidos.

- **Avaliar tecnologias de backup**, assim como **requisitos de recuperação e de manutenção de dados e aplicativos**, é um **passo essencial** para garantir a implementação bem-sucedida da solução de backup e recuperação, visando facilitar a recuperação fácil dos backups e arquivos conforme necessitado pela empresa. Precisa ser **Avaliado pela Empresa**:
  - O **montante de perda de dados e o tempo inativo** que uma empresa pode suportar são as preocupações primárias na seleção e implementação de uma estratégia específica de backup.
  - Outro fator é o **período de retenção**, que define por quanto tempo uma empresa precisa manter os backups (considerar o **tipo da mídia de backup** com base no período de conservação e acessibilidade dos dados);
  - Decisão sobre o **horário** mais apropriado para a execução do backup para minimizar qualquer **interrupção** nas operações de produção;
  - **Decisão sobre local** (plataformas onde está), **tamanho e numero de arquivos** (custo computacional), **tipo de mídia** utilizada para armazenar, uso de **compactação**, dentre outras.
  - Decisão do **momento** da operação de **restauração** são importantes;

Contextualização - Objetivos do Backup

- **Recuperação de Desastres**: As cópias de backup são usadas para restaurar os dados (por completo) em um local alternativo quando o local principal está incapacitado em virtude de um desastre.
  - método de backup baseado em fitas - fita do backup é enviada e armazenada em outro local
  - tecnologia de replicação remota para replicar dados em um local de recuperação de desastres - trazer sistemas de produção de volta on-line em um **período de tempo** relativamente curto

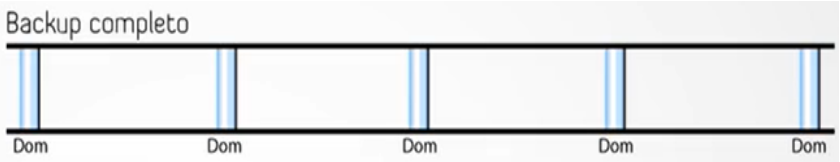
- **Arquivamento**: backup realizado quando a informação precisa ser arquivada por um longo periodo de tempo, como uma gravação telefonica, SMS, e-mail, notas Fiscais, dentre outros;
  - Apesar do **CAS (contente addressed storage)** ter surgido como solução principal para arquivamento de conteúdo fixo (recuperadas com base em seu conteúdo), muitas empresas de pequeno e médio porte ainda utiliza backups tradicionais;
  - CAS - O armazenamento endereçado a conteúdo é **um sistema baseado em objeto que foi feito para armazenar e gerenciar dados de conteúdo fixo e** acesso mais eficientes de dados fixos que geralmente não mudam com o tempo;

- **Backup Operacional**: realizado quando é necessário atualizar um sistema e SO virtualizado, um programa, rotinas ou até mesmo de documentos/arquivos visando garantir sua integridade dos dados antes desta atualização em caso de problemas;
  - Para restaurá-los no caso de perda de dados ou corrupções lógicas que podem ocorrer durante a atualização (virtualização de servidores);
  - Backups operacionais são criados para as informações ativas de produção a partir de técnicas de **backup incrementais ou diferenciais** (iremos ver depois);
    - Um exemplo de backup operacional é um executado para um banco de dados de produção antes de uma grande atualização em lote. Isso garante a disponibilidade de uma cópia limpa do banco de dados de produção se a atualização em lote o corromper.

Granularidade do Backup

- **Com base na granularidade** (divisão em partes menores ou como um todo), os **backups podem ser classificados** como: **completos**, **cumulativos** e **incrementais**;
  - A maioria das organizações utiliza uma combinação desses três tipos de backup para satisfazer seus requisitos de backup e recuperação;

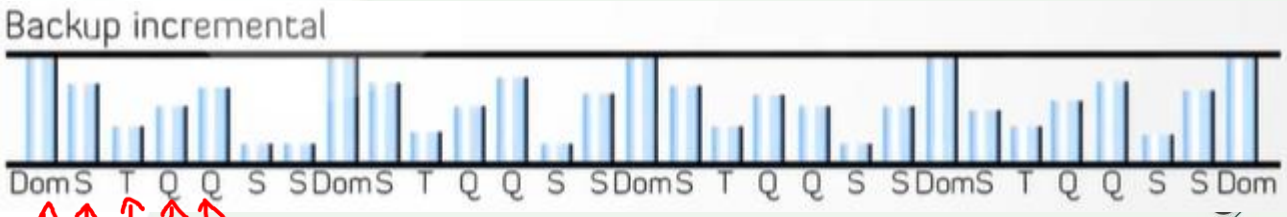
- **Backup Completo**: é feito sobre os dados integrais nos volumes de produção em determinado momento. Um backup completo é criado a partir da cópia dos dados dos volumes de produção para um dispositivo de armazenamento secundário.
  - P.ex: semanalmente, todo domingo;
  - Vantagem:
    - **cópia idêntica** do ambiente de produção
  - Desvantagem:
    - um desastre na terça feira, **perde-se os dados** de segunda e de terça, pois temos apenas o backup de domingo;
    - tempo de execução da **atividade demora até 10 vezes mais**;
    - **Grande espaço** de armazenamento destinado;



unoeste.br

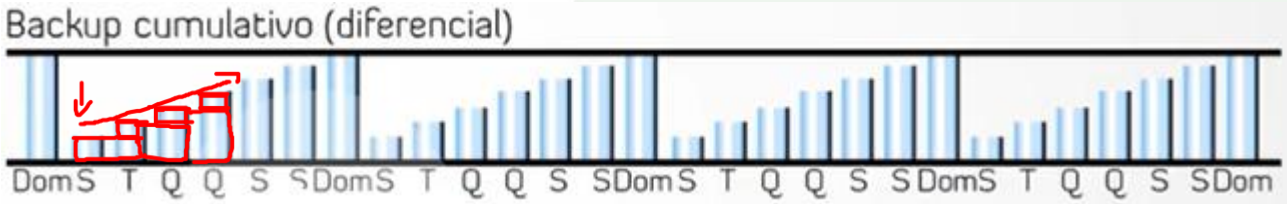
Granularidade do Backup

- **Backups Incrementais**: copiam apenas os dados que foram alterados desde o último backup, o que tiver ocorrido mais recentemente.
  - **Ocorre apenas o backup do que foi incrementado/alterado da informação no dia;**
  - Vantagem:
    - Esse **processo é muito mais rápido** (porque o volume de dados gravados é restrito aos dados alterados) que o backup completo, e, por gravar somente arquivos alterados, **ocupa menos espaço**.
  - Desvantagem
    - mas **demora mais tempo para restaurar**, pois para que haja a recuperação de arquivos é necessário **restaurar o último backup full e seus respectivos fragmentos incrementais** subsequentes.
  - P.ex: se ocorre a perda na quarta feira, perde-se apenas de quarta feira, pois dos dias anteriores tem-se armazenado no incremento



Granularidade do Backup

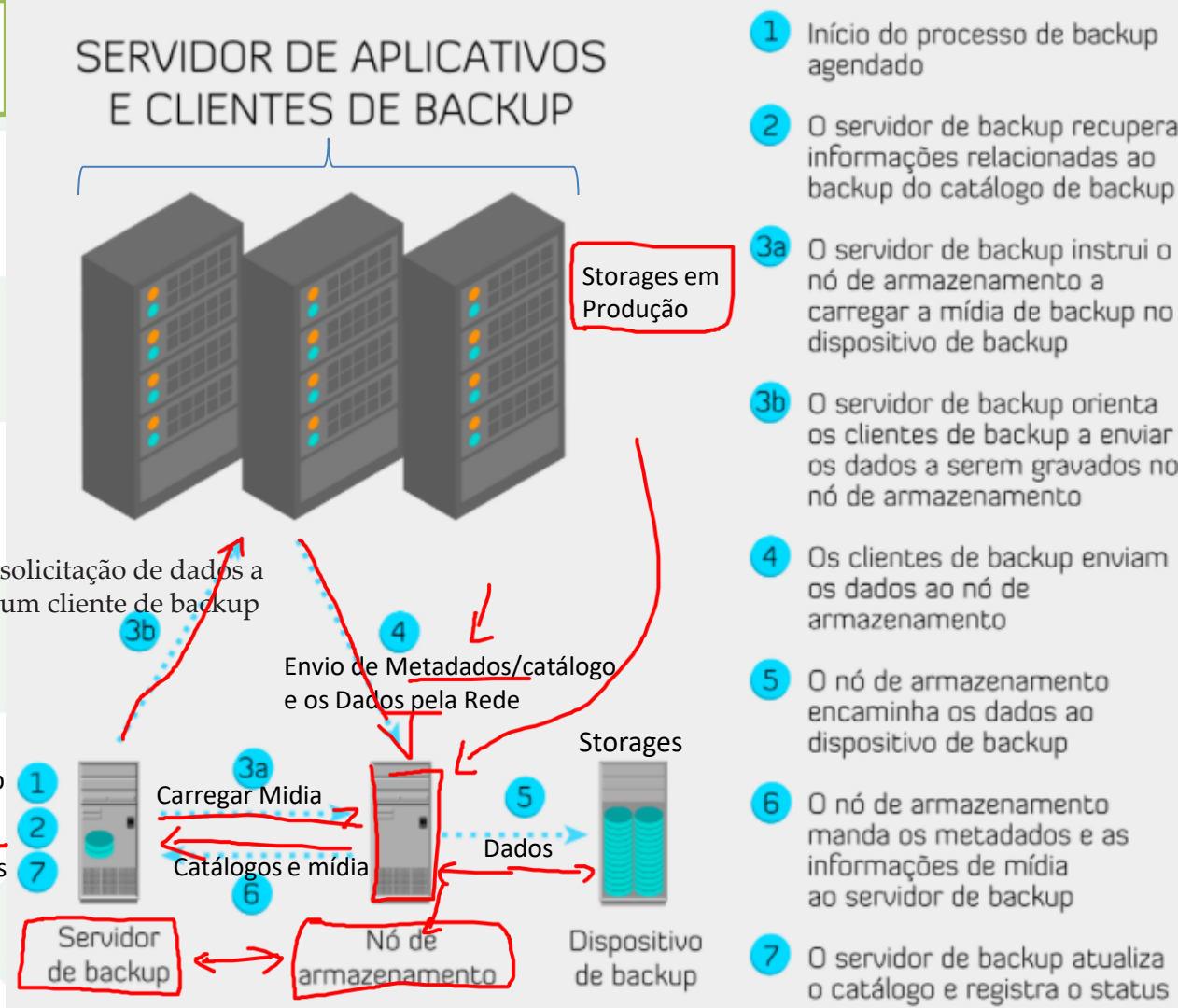
- **Backups Cumulativos (diferenciais):** copia os dados de cada dia, que foram alterados desde o último backup completo (porque eles foram adicionados ou modificados desde o último backup completo).
  - Backup é **realizado constantemente a cada dia** e no **domingo o backup total**;
  - O backup cumulativo **copia, diariamente, todos os arquivos adicionados ou modificados (vai cumulando) desde o último backup completo**.
  - Desvantagem
    - Este método **demora mais do que o backup incremental**,
  - Vantagem
    - mas é **mais rápido de restaurar – backup cumulativo**.
  - P.ex: se ocorrer um problema na quarta feira, perde-se apenas o de quarta feira, tem-se a segunda e terça armazenadas em backup;



Processo de backup

nó de armazenamento (servidor de mídia) é responsável pela gravação dos dados no dispositivo de backup (em um ambiente de backup, um nó de armazenamento é um host que controla dispositivos de backup)

Os **catalogos** (**metadados/indices**) podem estar em outro dispositivo de backup

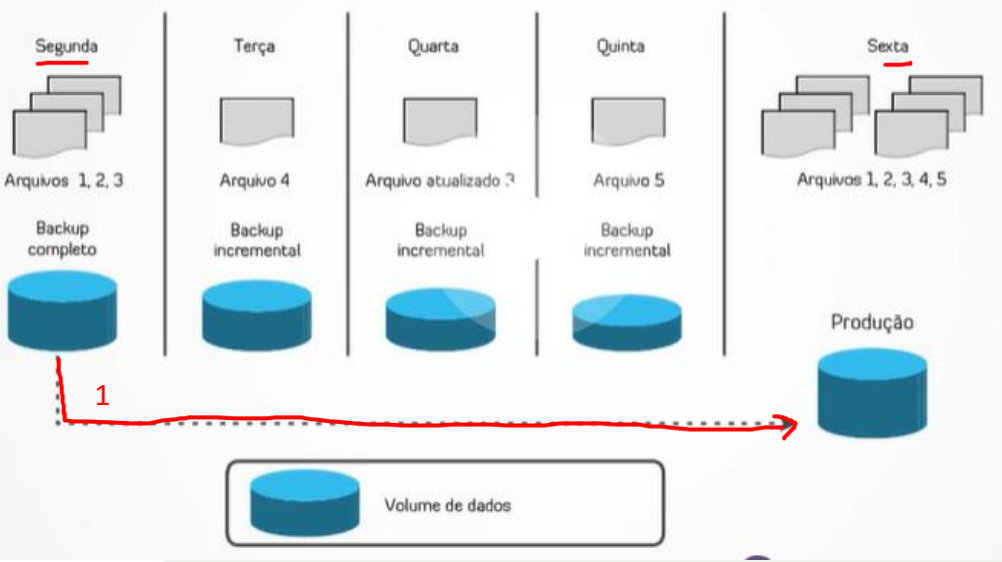


Granularidade do Backup

- **Operações de Restauração (indicadores):** variam com a granularidade do backup;
  - **RPO** - Recovery Point Objective (Ponto Objetivo de Recuperação), o RPO é o **indicador** utilizado para que a empresa saiba a **quantidade de recursos mínimos a serem recuperados em caso de falhas ou perda de dados**.
    - O RPO **define o LIMITE TOLERÁVEL de perda de dados para uma empresa e especifica o intervalo de tempo entre dois backups**. Em outras palavras, o **RPO determina a frequência dos backups**.
    - Exemplo: se o aplicativo A requerer um RPO de um dia, será necessário que os dados sejam gravados pelo menos uma vez ao dia.
  - O período de retenção de um backup também é derivado de um RPO especificado para recuperação operacional.
    - Exemplo: os usuários de um aplicativo A podem requerer a restauração dos dados desse aplicativo a partir da sua cópia de backup operacional, que foi criada há um mês. Isso **determina o período de retenção do backup**.
  - **RTO** - Recovery Time Objective - Objetivo do Tempo de Recuperação - RTO é um **indicador** que mensura o **tempo máximo gasto para recuperação de um sistema ou uma informação** aós ficar indisponível após uma falha.
    - combinação de **diferentes soluções de backup (completo, incremental ou cumulativo)**para minimizar o tempo de recuperação;
    - RTO **influencia o tipo de mídia de backup** que deve ser empregado (HD X SSD)

Granularidade do Backup

- **Operações de Restauração:**
  - **Restauração por meio de um Backup Completo**: fornece um repositório único a partir do qual os dados podem ser facilmente restaurados.
    - Quando ocorre um backup completo (tipo toda segunda feira), se **restaurarmos** o mesmo (**passo 1**), vamos ter no ambiente de producão **toda aquela informação ou volume de dados** montados na segunda feira;

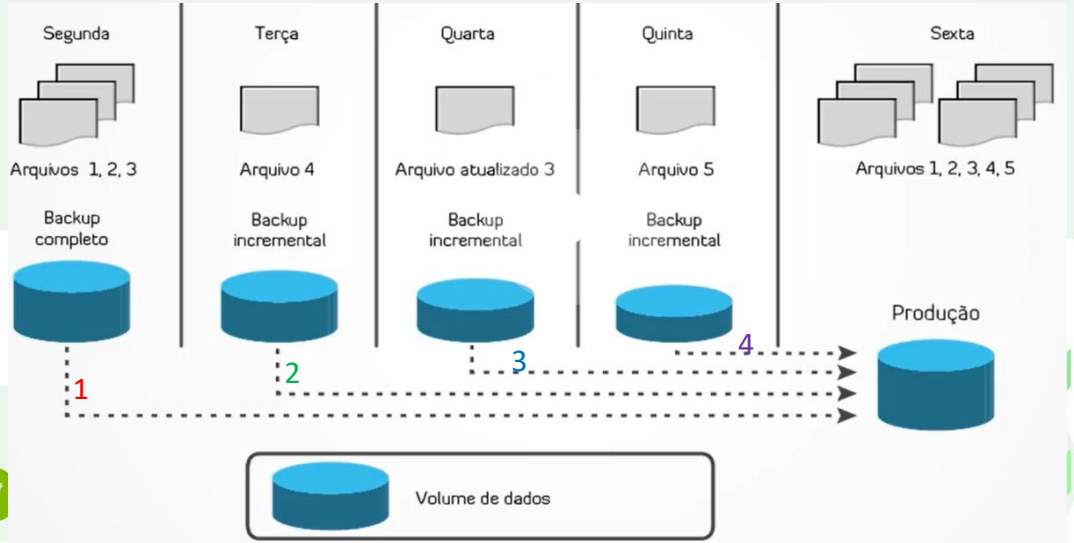


Granularidade do Backup

- **Operações de restauração**:
  - **Restauração por meio de um Backup Incremental**: requer o **último backup completo e todos os backups incrementais disponíveis** até o ponto de restauração.
  - Exemplo:
    - Primeiro se faz a **restauração do ultimo backup completo** (Segunda feira) (**passo 1**),
    - Depois, para ter o **incremento de cada dia**, é realizada o backup incremental da terça (**passo 2**) para ter o backup da terça, depois da quarta (**passo 3**) para ter a de quarta feira, depois a de quinta (**passo 4**) para ter a de quinta, e assim por diante;

A cada dia um backup incremental é executado

- Terça Feira - Arquivo 4 é copiado durante o backup incremental na terça à noite;
- Arquivo 3 modificado é copiado durante o backup incremental na noite de quarta.
- o backup incremental na quinta reproduz apenas o Arquivo 5;

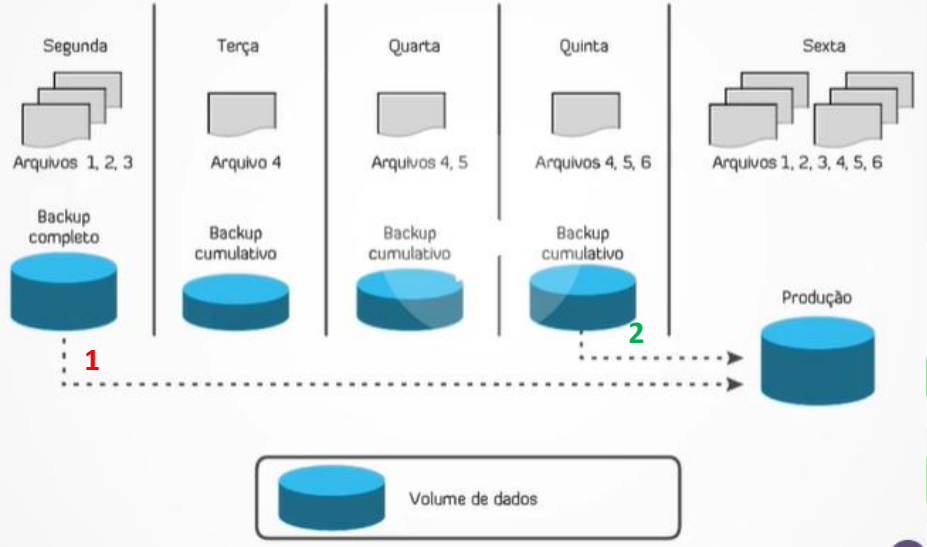


Granularidade do Backup

- **Operações de restauração**:
  - **Restauração com base em um Backup Cumulativo**: necessita do **último backup completo e do backup cumulativo mais recente**.
  - Exemplo:
    - Restaura o backup completo da segunda feira (**passo 1**) para ter o ambiente em produção;
    - Depois, basta restaurar apenas o último backup acumulativo do dia desejado, assim já teremos as dados dias anteriores. Neste caso, o desejado é quinta feira (**passo 2**), assim, já teremos a restauração dos dados acumulados de quarta e terça;

A cada dia um backup cumulativo é executado

- Terça Feira - Arquivo 4 é adicionado e nenhum outro arquivo é modificado desde o último backup completo da noite de segunda-feira. Backup cumulativo da noite de terça-feira copia apenas o Arquivo 4;
- Quarta feira: Na quarta, o Arquivo 5 é adicionado. O backup cumulativo que ocorre na noite da quarta-feira copia o Arquivo 4 e o 5 porque eles foram adicionados ou modificados desde o último backup completo;
- Quinta feira: o Arquivo 6 é adicionado. Portanto, o backup cumulativo na noite da quinta-feira copia todos os três arquivos: 4, 5 e 6.



Métodos de backup

- **Baseados no estado do aplicativo quando o backup é executado**: backup dinâmico e backup estático;
  - Em um **backup estático**, o aplicativo não fica ativo durante o backup.
    - É claro que a desvantagem de um backup estático é que o **sistemas ou banco de dados fica inacessível** para os usuários durante o processo de backup - Tempo de Inativo
    - **Vantagem é a CONSITENCIA, DESEMPENHO MAIOR, MENOS ERROS, etc**
  - Em um **backup dinâmico**, o **aplicativo está em execução/produção**, sendo que os usuários estão acessando seus dados durante o processo.
    - O backup dinâmico é usado em situações nas quais **não é possível desligar o sistema ou banco de dados**, etc
    - Torna mais desafiador porque os dados estão sendo usados e alterados ativamente;
    - Ex: Um arquivo aberto é **bloqueado** pelo sistema operacional e não é copiado durante o processo de backup até que o usuário o feche; Aplicativo de backup fornece agentes de arquivos abertos, que interagem diretamente com o sistema operacional e permitem a criação de cópias consistentes de arquivos abertos;
    - A desvantagem associada a um backup dinâmico é que o desempenho geral devidas as diversas ações para manter a consistência;

Métodos de backup

- **Método de cópia point-in-time (PIT):**
  - é **implantado em ambientes nos quais o impacto do tempo inativo** causado por um backup estático ou o desempenho resultante de um backup dinâmico **sejam inaceitáveis**.
  - Quando o seu banco de dados perde informações, devido a ocorrência de um problema ou remoção por engano, é importante recuperar estes dados exatamente como eram antes do desastre. Se utilizado o Dump (cópias full), tradicional método de backup, haverá um período sem dados copiados, entre um backup e outro.
  - **Um PIT é uma cópia de dados, arquivos ou bancos de dados em um momento específico**. O PIT é útil se houver necessidade de **recuperar e restaurar dados de um momento específico ou do último instantâneo PIT recente**.
  - O **PITR (*Point-in-time recovery*)**, permite fazer com sucesso, **cópias automáticas de cada transição realizada**, ou seja, dos **arquivos transacionais WAL** (processo de arquivamento dos arquivos de WAL – Write Ahead Log).
    - Registro/Log prévio da escrita (WAL = write ahead logging)
  - **Possibilita também recuperar dados gravados em qualquer ponto do tempo**, segundos, minutos, horas, dias, até mesmo, semanas atrás. O tempo retroativo do backup dependerá do período em que as transições copiadas serão mantidas, período de retenção do PITR.

Métodos de backup

- **Recuperação bare-metal (BMR) – criado pela IBM**
  - se refere a um **backup no qual todos os metadados, informações de sistema e configurações de aplicativos são gravados** apropriadamente para gerar uma **recuperação de sistema completa**.
  - **A BMR cria o sistema básico**, que abrange particionamento, layout do sistema de arquivos, sistema operacional, aplicativos e todas as configurações relevantes.
    - **Backup bare metal é a cópia física (completa) de todos os programas e dados contidos em hard disks ou memórias SSD** de servidores ou computadores para outros equipamentos, geralmente storages, através da criação uma imagem exata do sistema fora do ambiente para recuperação em caso de desastre.
  - **A BMR recupera primeiro o sistema básico antes de iniciar a recuperação dos arquivos de dados.**
    - Os motivos mais comuns para a execução de uma recuperação bare metal são a falha ou enchimento completo do disco rígido e você deseja atualizar (migrar) para uma unidade maior ou migrar para um hardware mais recente.

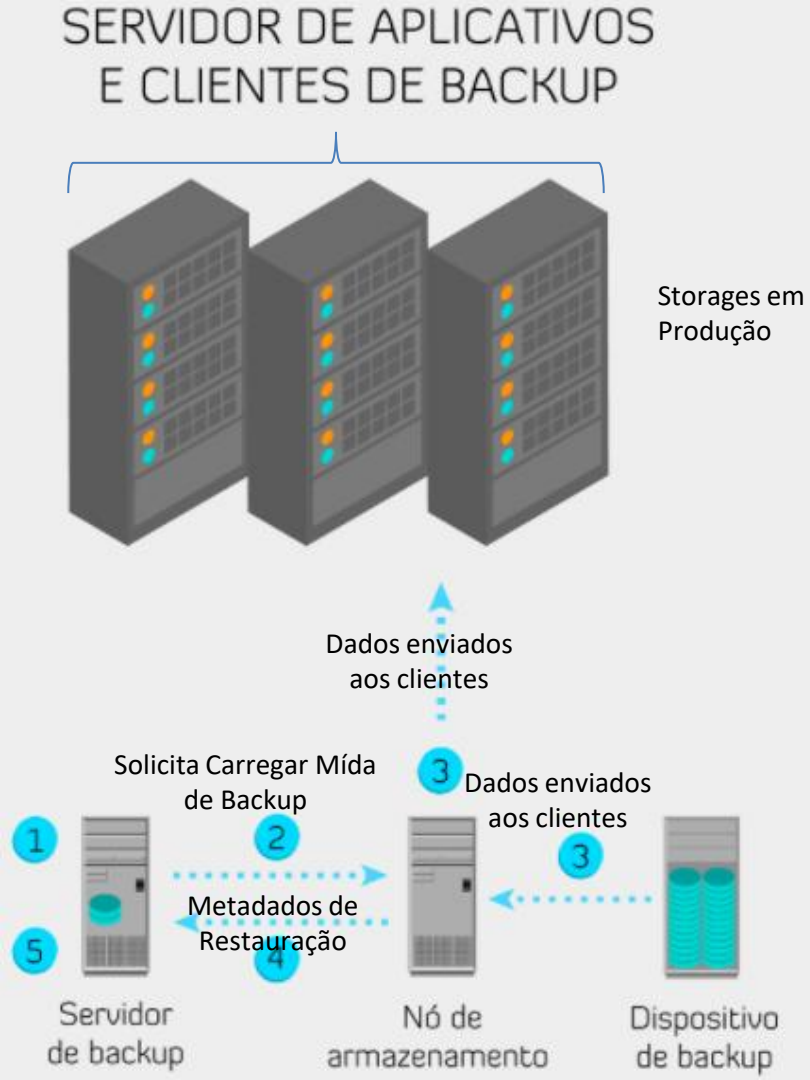
Processo de Restauração

Administrador abre o aplicativo de **restauração**

Administrador então **determina os dados** a serem restaurados e o ponto específico do tempo

Varrer catalogo gravado para identificar os dados

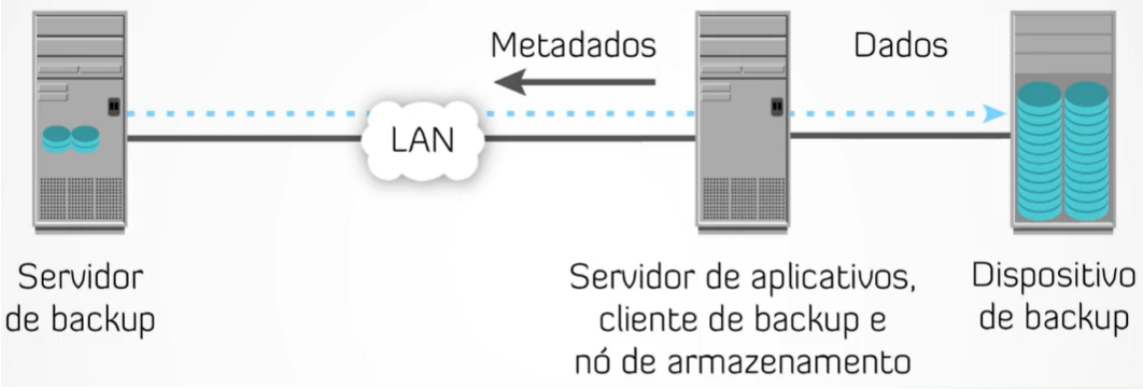
Atualiza Catálogo



1. O servidor de backup varre o catálogo de backup para identificar os dados a serem restaurados e o cliente que os receberá
2. O servidor de backup instrui o nó de armazenamento a carregar a mídia de backup no dispositivo de backup
3. Os dados são então lidos e enviados ao cliente de backup
4. O nó de armazenamento encaminha metadados de restauração ao servidor de backup
5. O servidor de backup atualiza o catálogo

Topologias ou Arquiteturas de Backup

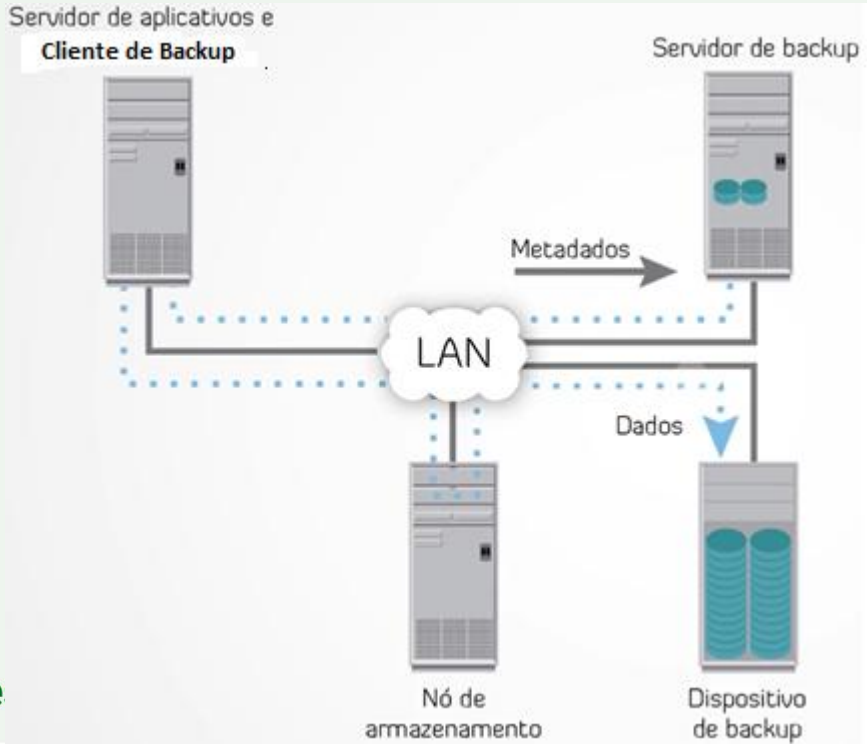
- Três topologias básicas são usadas em um ambiente de backup:
  - **Backup de Conexão Direta – DAS – Direct-Attached storage**
    - dispositivo de backup é **ligado imediatamente ao nó de armazenamento** - dispositivo de backup que não é compartilhado;
    - Apenas os **metadados são enviados ao servidor de backup** através da LAN. Essa configuração **libera a LAN do tráfego de dados** do backup;



Neste exemplo, o cliente também age como um nó de armazenamento que grava dados no dispositivo de backup

Arquiteturas de Backup

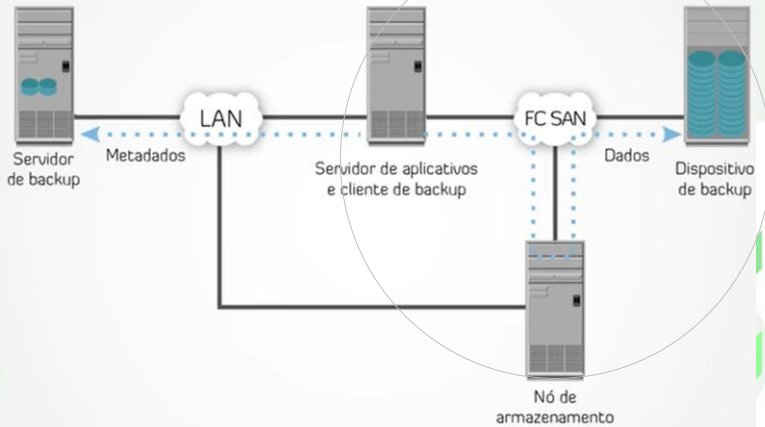
- **Backup baseado em LAN - NAS – Network-Attached Storage**
  - Os dados a serem gravados são transferidos do cliente de backup (origem) para o dispositivo de backup (destino) por meio da LAN;
  - **Nó de armazenamento recebe do cliente e grava os dados** no dispositivo de backup;
  - **Servidor de Backup recebe os metadados do cliente e atualiza seus catálogos**;
  - O uso da LAN afeta o desempenho;
    - Alternativa: configuração de redes separadas para backup e a instalação de nós de armazenamento dedicados para alguns servidores de aplicativos



unoe

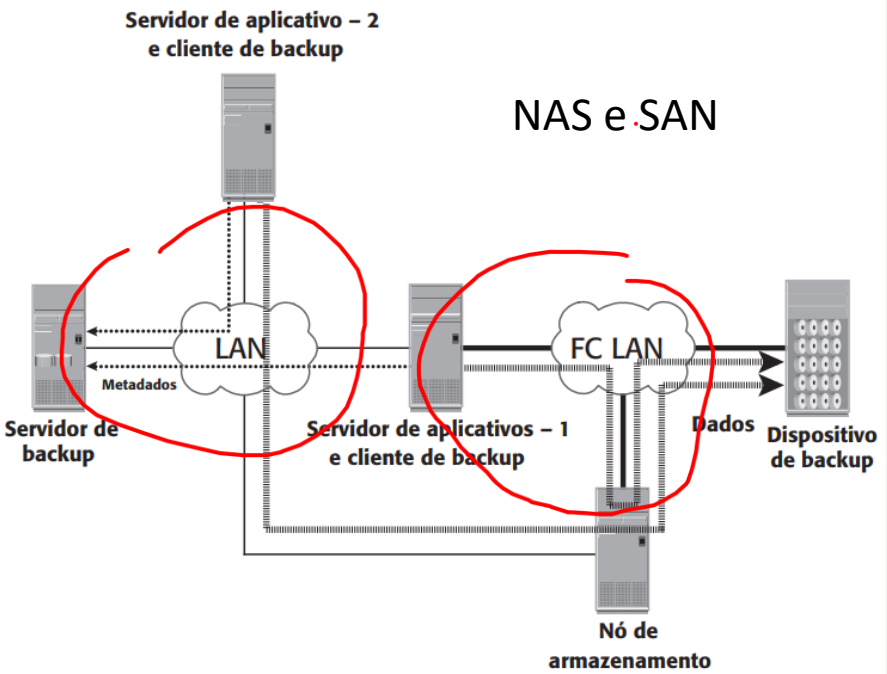
Arquiteturas de Backup

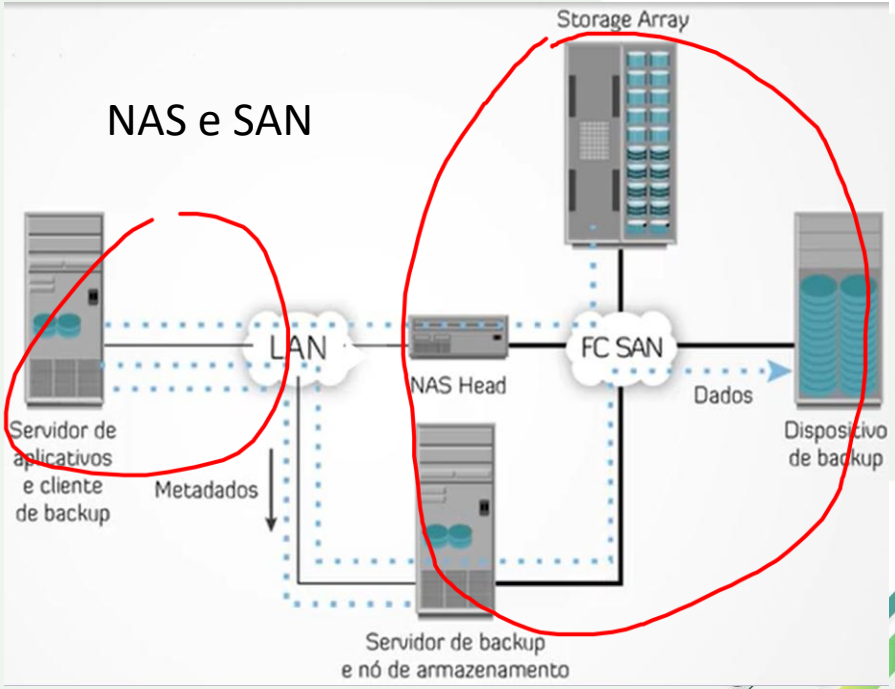
- **Backup baseado em SAN – Storage Area Network**
  - A topologia de backup baseado em **SAN é a solução mais apropriada** quando um dispositivo de backup precisa ser compartilhado entre os clientes.
  - Neste caso, o **dispositivo de backup e os clientes são anexados à SAN**.
  - **Os clientes leêm os dados dos servidores na SAN e gravam no dispositivo de backup anexado à SAN via Fibra Ótica**.
  - O **tráfego dos dados de backup fica restrito à SAN** e os **metadados do backup são transportados pela LAN** para o servidor de backup.
  - O desempenho da LAN não é degradada nesta configuração:



Topologias de Backup

- **Backup baseado em Topologias Mistas ou Híbridas**





*

UA	Nome da Unidade de Aprendizagem
2	Estrutura de uma política de segurança de informação

- **Dentro das corporações**, a necessidade dos usuários seguirem determinado script de **boas práticas é fundamental**.

- A **política de segurança da informação (PSI)** é um documento que deve conter **conjunto de normas, métodos e procedimentos o qual deve ser comunicado a todos os funcionários** visando manter seguras todas as suas informações (indicará **formas seguras de lidar com informações**). É **imprescindível** que haja um manual que indique quais são os **bons hábitos a serem seguidos**.

- Na **elaboração de uma PSI**, deve-se levar em consideração a **norma NBR ISO/IEC 27001:2005**, onde são encontradas as **melhores práticas** a fim de **iniciar**, **implementar, manter e melhorar a gestão de segurança da informação nas organizações**.
  - empresas podem ser **certificadas pela ISO/IEC 27001**

- **A ISO 27001 estabelece requisitos**. Se uma organização deseja certificar seu Sistema de Gerenciamento de Segurança da Informação (SGSI), ela precisa estar em conformidade com todos os requisitos da ISO 27001. Ex: todos os usuário precisam ter senhas
- Por outro lado, **a ISO 27002 são práticas recomendadas que não são obrigatórias**. Isso significa que uma organização não precisa estar em conformidade com a ISO 27002, mas pode usá-la como inspiração para implementar os requisitos da ISO 27001. Ex: recmencada que a senha seja com 8 letras, numeros etc.

Conceito de PSI e sua importância

- A **PSI é um manual de procedimentos** que descreve **como os recursos** de tecnologia da informação (**TI**) da empresa **devem ser protegidos e utilizados**, representando o pilar da eficácia da segurança da informação.
  - **diminuir a probabilidade da ocorrência de incidentes** que provoquem a indisponibilidade do serviço, furto ou até mesmo a perda de informações;
  - o **intervalo médio** utilizado para a **revisão da política é de 6 meses a 1 ano**, porém deve-se realizar uma revisão sempre que forem identificados fatos novos; Ex: de acordo com LGPD

- A **PSI** tem como objetivo manter os **Pilares da Segurança da Informação:**
  - **Confidencialidade** — garantia de que a informação é acessível somente para pessoas autorizadas a terem acesso;
  - **Integridade** — garantia da integridade consiste em permitir que a informação não seja modificada ou destruída sem autorização, seja legítima e permaneça persistente;
  - **Disponibilidade** - trata-se da garantia de que os usuários autorizados obtenham acesso à informação e aos ativos correspondentes sempre que necessário.

Composição básica da PSI

- Um componente importante consiste em **permitir que projetistas definam uma política de segurança**, um **conjunto de regras bem definidas** que incluem os **seguintes componentes**:
  - **Sujeitos**: agentes que interagem com o sistema;
    - Indivíduos podem ser identificados por seus nomes ou cargos, como presidente, diretor ou gerente. Grupos podem ser definidos usando termos como usuários, administradores, professores, diretores e gerentes.
  - **Objetos**: recursos de informação e computacionais que uma política de segurança deve proteger e administrar
    - Exemplos de informação: documentos críticos, arquivos e bancos de dados, e recursos computacionais servidores, estações de trabalho e software;
  - **Ações**: coisas que os sujeitos podem ou não fazer com relação aos objetos
    - leitura e escrita de documentos, atualização de software em um servidor web e acesso aos conteúdos de um banco de dados;
  - **Permissões**: mapeamentos entre sujeitos, ações e objetos, que estabelecem claramente quais tipos de ações são permitidas ou proibidas;
  - **Proteções**: características específicas de segurança ou regras incluídas na política visando atingir determinados objetivos de segurança, como confidencialidade, integridade, disponibilidade ou anonimato;

AGDLP
SAM-ALP
Linux

Composição básica da PSI

- **Formar um Comitê de segurança da informação**, constituído por:
  - **profissionais de diversos departamentos**, como informática, jurídico, engenharia, infraestrutura, recursos humanos, etc. para divulgar e estabelecer os procedimentos de segurança, **reunindo-se periodicamente** com o objetivo de manter a segurança em todas as áreas da organização;

- **Para elaborar uma política de segurança e seus regulamentos** complementares, devemos considerar as **seguintes etapas**:

1. **Inicialização do projeto** — nessa etapa, **descreve-se o projeto e justifica-se** e declara-se o seu objetivo. Depois, é preciso definir o **escopo do projeto**, limitado em relação à abrangência dos documentos gerados e/ou em relação ao detalhamento do texto destes documentos. Nesta etapa, é importante que sejam **registradas as restrições**, isto é, os fatores que podem impactar o projeto e impedir a construção do produto final.

Composição básica da PSI

2. **Definição das premissas assumidas pelo projeto** — premissas são fatos, situações ou compromissos tomados como **existentes**, isto é, que **acontecerão**.

3. **Desenvolvimento do projeto** — deve-se realizar um **levantamento** do que existe na organização ou no grupo de organizações em relação ao tema trabalhado para a definição dos **regulamentos**.

4. **Desenvolvimento dos regulamentos** — com base nos levantamentos e nas reuniões de trabalho, o gestor da segurança da informação precisa **desenvolver os regulamentos**.

5. **Concordância dos documentos** — todos os documentos gerados devem estar em **conformidade** com o padrão dos documentos de regulamentação da **organização**. Deverá definir um padrão para as políticas e normas de segurança da informação.

6. **Entrega, comunicação e treinamento do produto** — é necessário realizar **formalmente** a entrega do projeto, pois, para regras que legislarão internamente a organização, é importante a **data da implantação** de cada um dos regulamentos. A partir da data de entrega, as **regras valerão** para todos os usuários da informação da organização;

7. **Definição dos processos de manutenção e atualização** — nessa etapa, define-se como acontecerão a **manutenção e a atualização** das políticas e normas de segurança da informação.

Composição básica da PSI

- **Estrutura de um documento de regulamento em segurança da informação**.
  - **Objetivo do documento** — nesse bloco, indicam-se o **objetivo do documento**, o que é o documento e o que a organização deseja comunicar com esse documento. Além disso, devem ser **alinhadas e indicadas a aderência desse documento** a outros **regulamentos, legislação, normas e estruturas de tratamento** de informações e projetos. Pode-se, também, indicar as razões da existência da política ou da norma.
  - **Escopo do documento** — nesse bloco, deve-se **indicar os ambientes físicos, os ambientes lógicos, os tipos de usuários, as regiões geográficas** ou outras definições que indicam os limites da aplicação do documento e das regras. Esse bloco aponta para quem e para quais ambientes organizacionais as regras serão aplicadas e exigidas.
  - **Definições ou glossário** — nesse bloco, deverão estar definidos os **termos específicos**, as **abreviaturas, os termos técnicos, os nomes-siglas de entidades** e áreas organizacionais, et No caso de nomenclaturas que não sejam de uso comum em vários níveis de usuários, deve haver uma explicação para que todos, inclusive os **leigos**, consigam compreendê-las.

Objetivo/justificativa

Escopo

Definições/glossário

Regras

Responsabilidade

Cumprimento

Composição básica da PSI

- **Estrutura de um documento de regulamento em segurança da informação.**
  - **Regras** — nesse bloco, teremos as **orientações, as regras e a organização** deseja que todos os usuários cumpram. Esse bloco é considerado a **essência do documento**. Aqui, a organização indicará o que deve ser feito, o que é obrigatório, o que não se pode fazer e os princípios que se deseja seguir. O importante é que as regras não deixem dúvidas para os usuários.

  - **Responsabilidades** — nesse bloco, devem ser definidas as responsabilidades referentes a documento, ou seja, **indicar o responsável pela atualização**, a revisão e a manutenção do texto do regulamento; **pelo treinamento** necessário para que os usuários consigam cumprir o regulamento; **pela divulgação** do texto para os usuários; e por outras ações necessárias para garantir que o documento será sempre verdadeiro, atualizado, passível de cumprir e de conhecimento de todos.

  - **Cumprimento** — nesse bloco, devem estar explícitas as possíveis **penalidades** caso o usuário não cumpra adequadamente as regras descritas no regulamento. É preciso, também, indicar o procedimento do usuário em caso de erro, dúvidas ou em situações que não estejam previstas no documento.

Objetivo/justificativa

Escopo

Definições/glossário

Regras

Responsabilidade

Cumprimento

Exemplos de Tópicos de uma PSI

- **Autenticação no Sistemas de Informação da Empresa:**
  - **Politicas de Senhas:** Senhas Seguras com no minimo 6 a 8 caracteres;
  - **Politicas de E-mails:**
    - Indicar ao usuário que não abra anexos com extensões .bat ou .exe
    - Avisar para desconfiar de remententes desconhecidos ou com nomenclaturas diferentes ou assinados de forma estranha como I Love You, Brasil é Maior, Pague sua Conta, etc;
  - **Politica de Acesso ao Internet:**
    - Recomendar ao usuário para não usar o computador da empresa para o entretenimento em horario de trabalho;
    - Que ele não jogue durante o serviço ou faça download de musicas ou videos;

- **Politica de Uso das Estações de Trabalho**
  - Alertar o usuário para **não instalar nenhum tipo de software** não autorizado;
  - Alertar para ficar atento para não ter MP3, filmes, fotos e Softwares com direitos autorais ou qualquer outro tipo de pirataria na estação;

Exemplos de Tópicos de uma PSI

- **Politica Social**
  - Alerta ao usuário para não falar sobre a PSI da empresa para terceiros ou em lugares publicos;
  - Não dizer a sua senha da empresa para ninguém; Se alguem usar sua senha vc será responderá;
  - Não digitar senhas e usuários em máquinas de terceiros, especialmente, fora da empresa;

- **Virus e Códigos Maliciosos**
  - Manter sempre o antivirus atualizado;
  - Não plugar HD externo ou pen drive ou colocar DVD ou CDROM na estação de trabalho que possa conter algum tipo de virus ou código malicioso;
  - Não instalar códigos Maliciosos na estação de trabalho;
  - Não disseminar códigos maliciosos entre a rede que se encontra dentro da empresa;

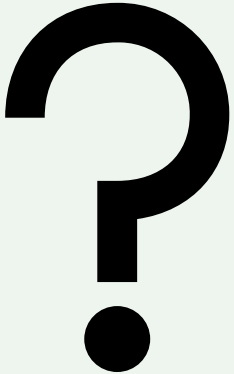
Exemplos de Tópicos de uma PSI

- Além desses tópicos é preciso indicar, no documento da PSI, **o porquê de ela estar sendo criada;**

- Caso for verificado que o funcionário não está cumprindo as regras definidas, **apontar quais punições serão aplicadas por não cumprir;**
  - Uma advertencia, uma chamade atenção ou uma perda de previlegio no sistema

- Uma **PSI deve ser atualizada em periodo curto**, no máximo 1 vez por ano;
  - Tudo muda e a PSI deve mudar tb.
  - Tem que estar no plano diretor da empresa;

*



Unoeste | EAD